

Aula 3 (Módulo 08) — Metodologia de Investigação de Alertas

Esta aula é diferente das anteriores. Em vez de te entregar um alerta já resolvido (o que eliminaria o valor de praticar), ela ensina o **método** que você vai aplicar toda vez que eu te der um `ALERTA #00X` de verdade para investigar, ao vivo, na conversa. Um alerta com resposta pronta escrita num documento não treina nada — a investigação real acontece interativamente.

1. O formato de um alerta de SOC

Todo alerta que vou te entregar segue um formato realista, parecido com o que qualquer SIEM (Módulo 09) gera:

```
ALERTA #001
Timestamp: 2026-09-19 14:32:07 UTC
Hostname: WKS-FINANCEIRO-07
Usuário: j.silva
IP de origem: 10.20.5.44
Processo: powershell.exe (PID 4821, pai: winword.exe PID 3102)
Evento: Sysmon Event ID 1 (Process Creation)
Severidade inicial: Média
```

Essa estrutura (timestamp, hostname, usuário, IP, processo, evento, severidade) é exatamente o mínimo que um analista de verdade recebe — às vezes menos, exigindo que você **peça** mais dados, como faria numa investigação real.

2. O método de investigação, passo a passo

Este é o roteiro mental que você deve seguir — e que vou usar para te guiar com perguntas quando você travar, em vez de entregar a resposta:

Passo 1 — Entender o alerta em si

Antes de investigar qualquer coisa externa, releia o alerta e pergunte: "o que exatamente esse alerta está dizendo que aconteceu?" Traduza para suas próprias palavras. Se não entender algum campo, é aí que perguntas técnicas específicas (não "o que eu faço?", mas "o que significa X?") ajudam mais.

Passo 2 — Reconhecer padrões já estudados

Compare o alerta com os padrões que você já viu nos módulos anteriores: processo pai/filho anômalo (Módulo 00/02)? Logon Type estranho (Módulo 02)? IP público desconhecido (Módulo 03)? Command line ofuscada (Módulo 02)? Você já tem o vocabulário — o exercício é **aplicá-lo**.

Passo 3 — Formular hipóteses

Não pule direto para "é malicioso" ou "é falso positivo". Formule pelo menos duas hipóteses concorrentes: uma que explique o alerta como **legítimo**, outra como **malicioso**. Isso evita viés de confirmação (procurar só evidência que confirma o que você já suspeitava).

Passo 4 — Pedir os dados que faltam

Numa investigação real, você **nunca** tem tudo de cara. Pergunte por dados adicionais específicos: "qual é a command line completa desse processo?", "esse usuário fez login de onde nas últimas 24h?", "houve conexão de rede associada a esse processo?". Eu vou responder como se fosse o ambiente real respondendo às suas queries — e a qualidade da sua investigação depende diretamente da qualidade das perguntas que você fizer.

Passo 5 — Decidir e justificar

Ao final, você classifica: **TP ou FP** (Aula 2), com **severidade** e uma **justificativa técnica** clara — não "acho que é suspeito", mas "é suspeito porque X, Y e Z, baseado em [conceito específico já estudado]".

Passo 6 — Documentar

Mesmo em um exercício, escreva o resultado como se fosse entrar num case de verdade (Aula 2): resumo, evidências levantadas, decisão final. Isso já é a prática que vai virar hábito profissional.

3. Quando travar

Se você não souber o próximo passo, isso é normal e esperado — não é sinal de estar mal preparado. Nesses momentos, em vez de te dar a resposta direto, vou fazer perguntas como:

- "O que você já sabe sobre esse tipo de processo pai/filho?"
- "Que módulo/aula a gente viu algo parecido com isso?"
- "Que pergunta você faria a um colega de N2 se estivesse travado nesse ponto?"

O objetivo é treinar seu **raciocínio investigativo**, não decorar respostas de casos específicos.

4. Como pedir uma simulação

Quando quiser praticar de verdade, é só me pedir algo como: *"me dá um ALERTA #001 pra eu investigar"* — vou gerar um cenário plausível (baseado em técnicas reais, catalogadas em MITRE ATT&CK quando fizer sentido) e conduzir a investigação com você seguindo esse método, sempre com Blue Team 70% / Red Team 30% (o "ataque" por trás do alerta serve só para você aprender a **detectar e investigar**, não para executar nada ofensivo de verdade).

5. Conectando com o resto da formação

Esta metodologia (Aula 3) usa:

- Conceitos técnicos (Módulos 00-06) → para reconhecer padrões
- Estrutura de SOC (Aula 1) → para saber quando escalar
- TP/FP/severidade (Aula 2) → para classificar corretamente
- Vai reaparecer, ampliada, em:
 - Threat Hunting (Módulo 14) → hipótese SEM alerta disparado
 - Incident Response (Módulo 15) → quando o TP é confirmado

6. Recapitulando o Módulo 08

- Um alerta de SOC segue um formato estruturado (timestamp, hostname, usuário, IP, processo, evento, severidade).
- Investigação segue método: entender → reconhecer padrões → formular hipóteses (legítima e maliciosa) → pedir dados faltantes → decidir com justificativa → documentar.
- Travar é normal — o valor do exercício está em ser guiado por perguntas, não em receber a resposta pronta.
- Simulações reais acontecem interativamente na conversa, não como texto estático — é só pedir quando quiser praticar.

Módulo 08 concluído (teoria) — as simulações de `ALERTA #00X` ficam disponíveis para você pedir a qualquer momento, inclusive revisitando depois de módulos futuros (SIEM, EDR, MITRE ATT&CK) para investigações cada vez mais realistas.

Próximo módulo

Módulo 09 — SIEM: como os alertas que acabamos de aprender a investigar são, na verdade, gerados — coleta, parsing, normalização, correlação e o laboratório prático de um SIEM real.

Fontes recomendadas

- **NIST SP 800-61 Rev. 2:** já citada nas Aulas 1 e 2 — cobre também a fase de "Detection and Analysis" com o mesmo espírito de metodologia estruturada usado aqui. <https://csrc.nist.gov/pubs/sp/800/61/r2/final>
- **MITRE ATT&CK:** será formalizado no Módulo 13, mas já vale conhecer a página oficial como referência de técnicas reais que alimentam cenários de simulação realistas. <https://attack.mitre.org/>